



Penetration Testing Services

Service Brochure

Leading Digital Trust

www.nucleus-systems.com | Centurion, Gauteng, South Africa

200+ Clients, 1000+ Engagements

Clients served and engagement successfully completed globally through strategic partners

CISSP, CSSP, CSSLP, and CompTIA Pentest + Certified Team

Over 60+ years combined team experience, industry-aligned accreditations

Tool Automation Aids a Manual-First Delivery Approach

Leverages automated tools for mapping vulnerabilities with manual validation to support the zero false-positive policy

“Security is a process, not a product,” According to Bruce Schneier. Penetration testing brings that process to life by simulating real adversaries, validating defenses, and uncovering what automated scans alone cannot; as Kevin Mitnick demonstrated, attackers exploit human and technical gaps alike, making a manual-first, evidence-driven approach essential to proving real-world risk before it becomes a breach

About Nucleus Systems

Nucleus Systems (Pty) Ltd is a secure digital services company specializing in cybersecurity, compliance, and digital trust assurance. Founded during the Fourth Industrial Revolution, we leverage modern technologies from inception delivering cutting-edge security without legacy constraints.

Over the past 11 years, we have served 200+ organizations through 1,000+ engagements globally across banking, fintech, digital public infrastructure, government, healthcare, and critical services. Our diverse team spans Africa, the UK, the US, India, Australia, and the UAE, bringing over 60 years of combined industry experience.

Our Core Values

Outside-In Perspective Align cybersecurity with market and customer needs	Low-Touch Engagement Expert skills that help clients help themselves	Open Standards Contributing to the global cybersecurity body of knowledge	Knowledge Transfer Empowering your team for long-term independence
---	--	---	--

Why Penetration Testing?

Penetration testing is a systematic, authorized process of probing systems, networks, and applications for exploitable vulnerabilities. It uses the same techniques employed by real attackers, with the explicit goal of identifying and remediating weaknesses before they are exploited maliciously.

Business Driver	Why It Matters
Regulatory Compliance	PCI DSS, ISO 27001, SOC 2, POPIA, GDPR, and HIPAA all mandate regular security testing of systems handling sensitive data
Validate Security Controls	Prove the effectiveness of existing security investments under real attack conditions
Establish Trust	Demonstrate security maturity to customers, partners, regulators, and investors
Ensure Resilience	Identify weaknesses in systems and processes that could disrupt business operations
Reduce Breach Cost	Early detection of vulnerabilities is significantly cheaper than responding to a breach

Benefits and Value of Penetration Testing

Penetration testing delivers measurable business and security value by proactively identifying weaknesses before they can be exploited. Beyond technical findings, it provides actionable insights that strengthen resilience, support compliance, and protect organizational reputation.

Business Driver	Value Delivered
Proactive Risk Reduction	Identify and remediate vulnerabilities before attackers can exploit them
Improved Security Posture	Strengthen defenses across networks, applications, and user environments. Meet regulatory and audit requirements with documented, repeatable testing
Informed Decision-Making	Prioritize security investments based on real-world risk and impact and Prevent reputational damage by reducing the likelihood of public security incidents
Continuous Improvement	Enable ongoing enhancement of security controls through regular assessments

Nucleus Systems delivers penetration testing that goes beyond compliance checkboxes — providing real-world validation of your security posture with every engagement.

Service 1: Web Application & API Penetration Testing

Our Web Application and API Penetration Testing service rigorously assesses the resilience of internet-facing applications, including web portals, RESTful and GraphQL APIs, and associated backend systems. The engagement simulates real adversarial behavior to uncover vulnerabilities that could compromise data confidentiality, integrity, or availability using a Grey Box testing method, with limited insight information in the form of login credentials.

Core Service Components

- Web Application Penetration Testing: manual deep testing of web interfaces, APIs, and backend integrations aligned to OWASP Top 10 and SANS/CWE
- Threat Simulation & Advanced Attack Emulation: MITRE ATT&CK-based adversary tactics combining automated and manual exploitation
- Verification & Retesting: post-remediation validation with evidence-based confirmation of vulnerability closure

Testing Methodology — What We Test

Test Area	Method	Standards
Endpoint & API Enumeration	Map all accessible application components, subdomains, virtual hosts, and API surfaces	OWASP API Top 10
Authentication & Session Testing	Login flows, token handling, MFA bypass, session fixation, and resets	OWASP A07
Authorization & Access Control	Horizontal/vertical privilege bypass, IDOR, forced browsing	OWASP A01
Injection & Input Validation	SQL injection, XSS, CSRF, SSRF, XXE, header injection	OWASP A03, CWE Top 25
Business Logic Abuse	Application-specific workflow manipulation, race conditions, and abuse of functions	OWASP Testing Guide
TLS & Configuration Reviews	Cipher suites, HTTP security headers, cookie flags, web server misconfig	CIS Web Benchmarks
Rate Limiting & Abuse Prevention	Throttle and lockout controls on login, reset, and sensitive endpoints	OWASP A04
Automated Scanning + Manual Verification	DAST tools augmented with expert manual testing — no unvalidated automated findings reported	NIST, MITRE ATT&CK

Tools

BurpSuite Professional (DAST, API interception proxy), Kali Linux toolchain, proprietary scripts for business logic and custom protocol testing.

Technical Requirements from Client

Item Required	Details
Application URLs	Internet-facing URLs; intranet apps via VPN or IP whitelisting
Test Credentials	Preferably admin-level; one set per role/persona
API Documentation	Swagger/OpenAPI specs, Postman collections if available
Testing Window	Agreed maintenance windows to minimise business disruption
Application Classification	Small / Medium / Large classification for accurate scoping (see p.5)

Service 2: Network Perimeter Penetration Testing

Our Perimeter Network Penetration Testing service simulates an external attacker probing your public-facing infrastructure, IP ranges, DNS records, internet-facing servers, remote access services, and perimeter controls. The engagement uncovers misconfigurations and exploitable vulnerabilities before malicious actors can leverage them.

Core Service Components

- Perimeter Network Penetration Testing: Manual deep testing of Internet-facing hosts, services, and configurations aligned to NIST, CIS, and SANS/CWE
- Threat Simulation & Advanced Attack Emulation: MITRE ATT&CK-based adversary tactics combining automated discovery with manual exploitation
- Verification & Retesting: Post-remediation validation with evidence-based confirmation that vulnerabilities are fully resolved

Testing Methodology — What We Test

Test Area	Method	Standards
Reconnaissance & Asset Discovery	External footprint mapping, DNS records, zone transfers, subdomain enumeration, OSINT	OSINT, NIST SP 800-115
Vulnerability Scanning & Manual Validation	Port/service scanning, version fingerprinting, manual confirmation, no unvalidated findings reported	NIST, CIS
Firewall & ACL Validation	Perimeter rule review, load balancer config, ACL, and segmentation checks	CIS Benchmarks
Remote Access & Authentication Testing	VPN, RDP/SSH, web admin portals, brute-force, bypass, weak credential testing	MITRE ATT&CK
Service Fuzzing & Attack Path Analysis	Protocol-level fuzzing (SMTP/FTP/SNMP), chained attack simulation to privileged access	MITRE ATT&CK
TLS & Certificate Reviews	Cipher suites, DNSSEC, SPF/DKIM/DMARC, certificate validity	NIST, CIS
Traffic Flood & Throttling Validation	Edge rate-limiting, WAF/IPS response, non-disruptive DDoS scenario testing	OWASP

Tools

Nmap & NSE Scripts (port/service scanning), Nessus Professional (vulnerability scanning), Metasploit Framework (controlled exploitation), Kali Linux Toolchain, custom scripts for firewall rule validation and perimeter segmentation checks.

Technical Requirements from Client

Item Required	Details
IP Ranges & DNS Records	All in-scope public IP ranges and domain names
Authorisation Letter	Signed authorization for testing critical perimeter services (VPN, mail servers, admin portals)
Testing Window	Agreed time slots to minimize operational disruption
Network Classification	Small / Medium / Large based on IP count and service exposure (see p.6)
Firewall Notification	Optional: whitelist tester IP ranges to prevent interference from IPS/IDS

Scoping Guidelines — Web Application & API Testing

Use the framework below to classify your application and determine the appropriate testing scope, duration, and preparation requirements.

Scope Factor	Small	Medium	Large
Web Pages / Screens	< 20 unique pages	20–50 pages	> 50 pages
API Endpoints	< 15 endpoints	15–40 endpoints	> 40 endpoints
Authentication Roles	1 role (e.g., admin)	2–3 roles	4+ roles or complex SSO/MFA
Third-Party Integrations	None or 1	2–3 integrations	4+ integrations
Microservices / Backend	Single service/monolith	2–4 services	5+ services or service mesh
Business Logic Complexity	Simple CRUD operations	Moderate workflow logic	Complex multi-step workflows
Typical Test Duration	3–5 business days	5–8 business days	8–15 business days

What to Prepare

Item	Small App	Medium App	Large App
Application URL(s)	Single URL	Primary + staging URLs	All environment URLs
Test Credentials	1 admin-level account	1 account per role	1 account per role, incl. API keys
API Docs	Not required	Swagger/Postman, if available	Full API spec + architecture diagram
Network Access	Direct internet access	VPN or IP whitelist	VPN + IP whitelist + staging access

Scoping Guidelines — Network Perimeter Testing

Use the framework below to classify your network environment and determine the appropriate scope, duration, and preparation requirements.

Scope Factor	Small (< 50 IPs)	Medium (50–100 IPs)	Large (> 100 IPs)
External IP Count	Up to 50 addresses	51–100 addresses	101+ addresses
Exposed Services	Web, mail, basic VPN	Web, mail, VPN, remote admin, databases	Full enterprise perimeter, CDN, multi-site
DNS / Subdomains	1 domain, few subdomains	1–3 domains, moderate subdomains	Multiple domains, extensive subdomain landscape
Remote Access Portals	None or 1 (VPN only)	2–3 (VPN, RDP gateway, admin portal)	4+ portals across multiple locations
Cloud-Hosted Infrastructure	Minimal or none	Partial cloud (hybrid)	Primarily cloud or multi-cloud
Firewall / IPS Complexity	Single perimeter firewall	Multiple zones or dual firewall	NGFW, WAF, IPS — multi-zone
Typical Test Duration	3–5 business days	5–8 business days	8–12 business days

What to Prepare

Item	Small Network	Medium Network	Large Network
IP Ranges	CIDR notation for all in-scope IPs	CIDR + per-site breakdown	Full asset inventory with cloud scope
Domain Names	Primary domain	All domains and subdomains	Full DNS inventory
Authorisation Letter	Required — signed	Required — signed	Required — signed, per-site if needed
Service Inventory	Not required	Recommended	Required (with port/protocol detail)
Testing Window	Business hours	After-hours or maintenance window	Per-zone maintenance windows

Deliverables — Every Engagement Includes

Deliverable	Description	Audience
Technical Findings Report	Detailed vulnerability descriptions, CVSS risk ratings, affected assets, reproduction steps, and evidence (screenshots, logs, PoCs)	Technical / Security Teams
Executive Summary Report	Business-language overview of risk posture, business impact, and strategic remediation priorities	C-Suite / Board
Remediation Roadmap	Prioritized action plan: critical/high findings first, with quick wins and longer-term fixes	Technical / Security Teams
Presentation & Debrief	Interactive walkthrough session with experts — questions answered, priorities aligned	All Stakeholders
Evidence Package	Structured folder of screenshots, logs, and PoC artifacts for each validated finding	Technical / Legal
Optional Retesting at 50% of the package costing	Post-remediation validation of all critical and high findings, with a written attestation letter	Technical / Compliance

Delivery Methodology, Timeline & Plan

Web Application & API Penetration Testing | Network Perimeter Penetration Testing

SERVICE 1

Web Application & API Penetration Testing

Typical Duration: 8–10 Business Days (excl. optional retesting)

Phase	Days	Key Activities	Output / Deliverable
1	Day 0	- Proposal & NDA signed - Kick-off meeting with stakeholders - Application URLs, credentials, and API docs received - Testing window and rules of engagement confirmed	Signed SOW, Kick-off Notes
2	Days 1–2	- OSINT and passive reconnaissance - Subdomain and virtual host enumeration - Application mapping and endpoint discovery - API surface identification	Attack Surface Inventory
3	Days 2–4	- Automated DAST scanning (BurpSuite) - Authentication & session management testing - Authorization and access control validation - Injection, XSS, CSRF, SSRF, and input validation	Validated Vulnerability List
4	Days 4–5	- Business logic abuse analysis - Rate limiting and abuse prevention checks - TLS, HTTP header, and configuration review - Manual exploitation of findings with PoC evidence	Exploitation Evidence Package
5	Days 5–6	- Risk rating (CVSS) and prioritization - Report drafting — technical findings and executive summary - Remediation roadmap creation	Draft Report
6	Days 7–8	- Final report QA and review - Executive presentation preparation - Debrief session with technical and leaders - Remediation guidance and Q&A	Final Report + Presentation
7	Day 30–60	- Client remediates critical/high findings - Nucleus Systems validates closures via retesting - Written attestation issued upon successful closure	Validation Report + Attestation (Optional)

SERVICE 2

Network Perimeter Penetration Testing

Typical Duration: 8–10 Business Days (excl. optional retesting)

Phase	Days	Key Activities	Output / Deliverable
1	Day 0	- Proposal & NDA signed - Kick-off meeting with stakeholders - IP ranges, DNS records, and authorization letter received - Testing window and rules of engagement confirmed	Signed SOW, Authorization Letter
2	Days 1–2	- Passive OSINT and DNS reconnaissance - Subdomain enumeration and zone transfer attempts - Port scanning and service fingerprinting (Nmap + NSE) - OS and service version detection	External Asset Inventory
3	Days 2–3	- Vulnerability scanning with Nessus Professional - Manual validation and false-positive filtering - Firewall and ACL rule analysis - TLS/certificate and cipher suite review	Validated Vulnerability List
4	Days 3–5	- Remote access and authentication testing (VPN, RDP, SSH, admin portals) - Protocol and service fuzzing (SMTP, FTP, Etc.) - Controlled exploitation with PoC evidence captured - Attack path analysis and privilege escalation simulation	Exploitation Evidence Package
5	Days 5–6	- Risk rating (CVSS) and prioritization - Report drafting — technical findings and executive summary - Perimeter hardening and network remediation roadmap	Draft Report
6	Days 7–8	- Final report QA and review - Executive presentation preparation - Debrief session with technical and leadership teams - Remediation guidance and Q&A	Final Report + Presentation
7	Day 30–60	- Client applies perimeter hardening and patches - Nucleus Systems retests all critical/high findings - Written attestation issued upon successful validation	Validation Report + Attestation (Optional)

Note: Timelines assume all technical dependencies (credentials, IP ranges, authorization letters, API documentation, and testing windows) are provided at kick-off. Engagements can be compressed if dependencies are immediately available. Retesting validations are optional and scheduled after client-led remediation, typically 30–60 days post-report delivery.

Pricing

The following pricing applies to standard engagements. All prices are in USD and exclude applicable taxes (VAT). Pricing is valid for 90 days from the date of proposal. Custom scoping or bundled packages are available upon request.

Web Application & API Penetration Testing

Application Size	Scope	Price (USD)
Small Web Application (mainly websites)	< 20 pages, < 15 API endpoints, 1 authentication role	\$10,500
Medium Web Application	20–50 pages, 15–40 API endpoints, 2–3 roles	\$16,500
Large Web Application	> 50 pages, > 40 API endpoints, 4+ roles or complex SSO/MFA	\$19,500+
Custom / Enterprise	Agreed on scope - multi-application or continuous testing programs	On Request

Network Perimeter Penetration Testing

Network Size	Scope	Price (USD)
Small External Network	< 50 external IPs, 1 domain	\$10,500
Medium External Network	50–100 IPs, up to 3 domains	\$16,500
Large External Network	> 100 IPs, multi-domain / multi-site	\$19,500+
Custom / Enterprise	Multi-zone, cloud, or continuous monitoring programs	On Request

Bundle: Web + Network Penetration Testing

Bundle	Includes	Price (USD)
Small Bundle	1 Small Web App + 1 Small Network (< 50 IPs)	\$15,000 (save \$12,000)
Standard Bundle	1 Medium Web App + 1 Medium Network	\$21,000 (save \$9,000)
Enterprise Bundle	1 Large Web App + 1 Large Network + Retesting	\$29,000+ (save \$10,000+)

Notes: All pricing excludes VAT/taxes. Valid for 90 days. Pricing may vary based on the complexity of the scope identified during the scoping call. Custom retainer and continuous testing programmes available. **Full retesting is priced at 50% of the original package price, subject to confirmation of no deviation from scope, or at a daily rate customized to the client's needs.**

Real security is tested, not assumed: In today's threat landscape, penetration testing is not a nice-to-have but a business-critical step in protecting trust, continuity, and compliance. Penetration testing provides the clarity decision-makers need to manage cyber risk with confidence. Nucleus delivers that clarity through a manual-first, zero-false-positive approach that turns technical findings into actionable business value, helping move from uncertainty to assurance with penetration testing that is practical, precise, and built to uncover what truly matters.

Get Started Today

Contact us to schedule a no-obligation scoping call

Godfrey Kutumela | godfrey.kutumela@nucleus-systems.com | +27 83 680 3427

www.nucleus-systems.com